

Integrazione di due siti con login unica (SSO con cookie condiviso)

Questo documento descrive come unificare due siti web con database separati in un unico sistema di autenticazione utilizzando cookie condivisi a livello di dominio. L'obiettivo è avere un'unica homepage, un sistema di login/registrazione centralizzato e sessioni valide su entrambi i siti.

Struttura dei domini - Homepage unica → **www.miosito.com** - Sito 1 → **app1.miosito.com**
- Sito 2 → **app2.miosito.com** - Servizio di autenticazione → **auth.miosito.com**

Flusso di login 1. L'utente accede a `www.miosito.com` e sceglie se entrare in `app1` o `app2`.
2. Se non è autenticato, viene reindirizzato a `auth.miosito.com/login`. 3. Dopo il login, `auth.miosito.com` crea un cookie valido per tutto il dominio `.miosito.com`. 4. Quando l'utente torna su `app1` o `app2`, il sito legge il cookie e valida la sessione con `auth.miosito.com`. 5. Il logout rimuove il cookie a livello di dominio, disconnettendo l'utente ovunque.

Esempio di codice (Node.js + Express)

```
// auth.miosito.com (Node.js + Express + cookie-session)
const express = require("express");
const session = require("express-session");
const bodyParser = require("body-parser");

const app = express();
app.use(bodyParser.urlencoded({ extended: true }));

app.use(session({
  secret: "supersecretkey",
  resave: false,
  saveUninitialized: false,
  cookie: {
    domain: ".miosito.com", // cookie condiviso
    httpOnly: true,
    secure: true,
    sameSite: "none"
  }
}));

// Login endpoint
app.post("/login", (req, res) => {
  const { username, password } = req.body;
  // Validazione contro DB utenti
  if (username === "admin" && password === "1234") {
    req.session.user = { name: username };
    return res.redirect("http://www.miosito.com");
  }
  res.status(401).send("Credenziali non valide");
});

// Validazione sessione
app.get("/validate", (req, res) => {
  if (req.session.user) {
    return res.json({ loggedIn: true, user: req.session.user });
  }
  res.json({ loggedIn: false });
});

// Logout
app.post("/logout", (req, res) => {
  req.session.destroy(() => {
    res.clearCookie("connect.sid", { domain: ".miosito.com" });
    res.redirect("http://www.miosito.com");
  });
});

app.listen(3000, () => console.log("Auth server su http://auth.miosito.com"));
```

Esempio di codice (PHP)

```
<?php
// auth.miosito.com (PHP + sessioni)
session_set_cookie_params([
    'domain' => '.miosito.com', // cookie condiviso
    'secure' => true,
    'httponly' => true,
    'samesite' => 'None'
]);
session_start();

// Login
if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_POST['username'], $_POST['password'])) {
    $username = $_POST['username'];
    $password = $_POST['password'];

    // Esempio: validazione con DB utenti
    if ($username === 'admin' && $password === '1234') {
        $_SESSION['user'] = ['name' => $username];
        header("Location: http://www.miosito.com");
        exit;
    } else {
        echo "Credenziali non valide";
    }
}

// Validazione sessione
if ($_SERVER['REQUEST_METHOD'] === 'GET' && $_SERVER['REQUEST_URI'] === '/validate') {
    header('Content-Type: application/json');
    if (isset($_SESSION['user'])) {
        echo json_encode(['loggedIn' => true, 'user' => $_SESSION['user']]);
    } else {
        echo json_encode(['loggedIn' => false]);
    }
}

// Logout
if ($_SERVER['REQUEST_METHOD'] === 'POST' && $_SERVER['REQUEST_URI'] === '/logout') {
    session_destroy();
    setcookie(session_name(), '', time() - 3600, '/', '.miosito.com');
    header("Location: http://www.miosito.com");
    exit;
}
?>
```

Struttura dei file consigliata - **homepage/** - index.html (homepage comune) - **auth/** - server.js (gestione login/logout/validazione) - db_users.sql (tabella utenti centralizzata) - **app1/** - app1.js (logica specifica del sito 1) - **app2/** - app2.js (logica specifica del sito 2)